

Einführung in die IT Sicherheit (Übungsaufgaben)

Henning Pagnia

DHBW Mannheim

Herbst 2026

**TOP
SECRET**

Aufgabe 1 (Systemsicherheit)

Überlegen Sie wie und warum welche Vorgehensweisen zur Systemsicherheit im Allgemeinen und Benutzerauthentisierung im Besonderen jeweils für Smartphones, Notebooks sowie stationären Desktop-Rechnern sinnvoll sind.

Bedrohungen:

Diebstahl (S, N: hoch, D: mittel)

Malware (alle: hoch/mittel)

Hardware-Angriff (alle: gering)

Defekt + Zerstörung (S: hoch, N: mittel, D: gering)

Schutz:

Authentifizierung:

+ password, passkeys (alle)

+ biometrisch (S, N, D)

+ MFA (multi factor) (alle) -> je nach Anwendung

Tracking: (S, N)

Backup (S -> cloud)

Remote delete (S, N)

Remote Lock (S, N)

Aufgabe 2 (Sicherheit im Rechenzentrum)

Überlegen Sie, welche Maßnahmen in einem großen Rechenzentrum (z.B. eines Providers) geeigneterweise zu ergreifen sind, um maximale Sicherheit und Zuverlässigkeit zu erreichen!

Aufgabe 3 (Sicherheitsprotokoll – Fair Exchange)

Beim E-Commerce tritt immer wieder die Situation auf, in der zwei Parteien Geld und Ware austauschen müssen. Liegt beides in digitaler Form (z.B. Binärprogramm und digitale Münzen) vor, so lässt sich der Austausch vollständig elektronisch durchführen.

- (a) Überlegen Sie, warum im Internet ohne ein besonderes Protokoll keine Fairness (d.h. der Austausch wird entweder tatsächlich vollzogen oder aber keine Partei erhält etwas) garantiert wird.
- (b) Konstruieren Sie ein Protokoll, mit dem ein solcher Austausch fair durchgeführt werden kann. Welche Nachteile hat Ihr Protokoll in der Praxis?
- (c) Überlegen Sie, in welchen besonderen Situationen Ihr Protokoll Fairness nicht garantieren kann!

Aufgabe 4 (Begriffsdefinition)

Bitte recherchieren Sie.

Welche Definitionen gibt es zu den folgenden Begriffen:

Authentisierung, Authentifizierung, Authentifikation und Autorisierung?

Authentisierung: da gibt man an, wer er ist. Also erste Schritt, hier wird die Identität behauptet, noch nicht überprüft.

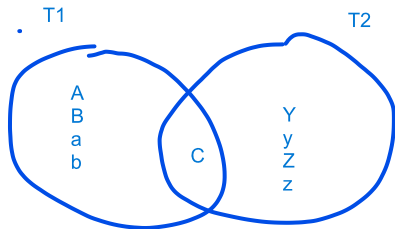
Authentifizierung: die Überprüfungsprozess, ob der Identität bei der Authentisierung korrekt ist.

Aufgabe 5 (Verschlüsselte Passwortlisten)

Ein Angreifer hat die folgende Unix-Passwortdatei gestohlen. Führen Sie einen Wörterbuch-Angriff durch, um möglichst viele Accounts zu knacken.

```
root:2EE0b8Kzqu2MI
kasperl:G9G8/W5oRgjZI
seapl:xBWlLOEcJZtv2
schorschl:zZoHld4UFdEp2
fritzchen:3ACuzSgFsWRMI
resi:BbXCprKkR4QAs
edi:xTeSe7snr/Als
```

A6 b) $F(A) = F(B) = F(Y) = F(Z) =$
 $F(a) = F(b) = F(y) = F(z) = 0$
 $F(C) = 1$



Aufgabe 6 (Dateischutz)

^{rwX}
A ---> a

^{rw}
A --> b

^{rw}
B --> a

^{rwX}
B --> b

In einer fünfköpfigen Firma gibt es den Chef (**C**) sowie vier Mitarbeiter, die jeweils in 2 Zweier-Teams zusammenarbeiten: **A** (ihm gehört die Datei **a**) und **B** (mit Datei **b**) in Team 1 (**T1**) sowie **Y** (mit Datei **y**) und **Z** (mit Datei **z**) in Team 2 (**T2**).

Wie kann man den Dateischutz so einstellen, dass die von je 2 Team-Mitgliedern gemeinsam verwendeten Dateien im Team gemeinsam bearbeitet werden können (also lesen und schreiben), das andere Team jedoch keinen Zugriff darauf hat? Der Chef soll alles lesen, aber nichts verändern können!

(a) mit ACLs?

(b) nach Bell-LaPadula?

(c) in Unix?

T1: A, B

a: rw A.%
rw %..T1
r-- C.%
--- %.%

Datei a

Benutzer	Zugriffsrechte
A	R, W
B	R, W
Chef	R

Datei b

Benutzer	Zugriffsrechte
A	R, W
B	R, W
Chef	R

Datei y

Benutzer	Zugriffsrechte
Y	R, W
Z	R, W
Chef	R

Datei z

Benutzer	Zugriffsrechte
Y	R, W
Z	R, W
Chef	R

Aufgabe 7 (Autorisierungskonzepte)

Recherchieren Sie, was man unter DAC, RBAC, ABAC, PBAC und ReBAC versteht und wie sich diese Konzepte unterscheiden.

A6 c)

r--rw---- C T1 a

r--rw---- C T2 y

T1: A, B, C

T2: y, z, c

aber: chmod 660 a

u+w

besser nicht

mit Verzeichnissen (Folie77)

rw-r-x--- A T1C Home A/

rw-rw-r-- A T1 Home A/a

rw-r-x--- Y T2C Home Y/

rw-rw-r-- Y T2 HomeY/y

T1C: A, B, C

T1: A, B

T2: Y, Z

T2C: Y,Z, C

mit SUID-Bit

rw-rw---- A T1 a

rwsr-x--- A T1C zeige_a

mit SGID-Bit



rw-r-x--- A T1C zeige_a

Aufgabe 8 (Speicherschutz: virtueller Speicher)

Gegeben sei folgendes Programmstück mit den in der Tabelle aufgeführten virtuellen Adressen.

Die Kachel- bzw. Seitengröße betrage jeweils 256 Worte.

Code:

```
(1) i = 0;  
(2) a[i] = 1;  
(3) i = i+1;  
(4) if (i ≤ 256) GOTO (2);  
(5) N = 100;  
(6) i = x;
```

Symboltabelle:

Daten	virt. Adresse
i	02DE
N	01B0
a[0]	0300
a[1]	0301
...	...
a[256]	0400
x	00F8

Der Prozess, der diesen Code ausführt, hat zu Beginn der ersten Anweisung die folgende Seitentabelle (Auszug):

Kachel	P-Bit	R-Bit	W-Bit	X-Bit	...
1F	1	0	0	1	...
00	1	1	0	0	...
93	1	1	1	0	...
46	1	1	1	0	...
E1	0	1	1	0	...

Welche realen Adressen gehören zu den Datenstrukturen und zu welchen Aktionen führt die Abarbeitung des obigen Codestückes?

Aufgabe 9 (Buffer Overflow)

In der Vorlesung haben wir besprochen wie ein Buffer Overflow auf dem Stack funktioniert. Untersuchen Sie, wie ein ähnlicher Angriff auf dem Heap ablaufen könnte!

Aufgabe 10 (Port Knocking)

Vergleichen Sie die Ansätze des (einfachen) Port Knocking, Single Packet Authorization und TCP Stealth miteinander! Geben Sie Ihre Quellen an.

Aufgabe 11 (Attack Trees)

Konstruieren Sie einen mindestens vierstufigen *Attack Tree* für den Angriff
“In den Louvre einbrechen (außerhalb der Öffnungszeit)”!

Aufgabe 12 (Orange Book)

Überlegen Sie sich, welche Kritikpunkte am *Orange Book* angebracht werden können.

Welche Kritikpunkte treffen auch auf die aktuellen Evaluierungssysteme, wie z.B. *Common Criteria* zu?

Aufgabe 13 (Covert Channels)

Betrachten Sie den folgenden verdeckten Kanal (*Covert Channel*):

In einen Strom von TCP-Segmenten wird jeweils nach jedem regulären gesendeten TCP-Segment ein leeres eingefügt, wenn über den verdeckten Kanal ein '0'-Bit gesendet werden soll und zwei leere für ein '1'-Bit. Gehen Sie von einer minimalen Segmentlänge von 100 Bytes und einer durchschnittlichen Segmentlänge von 1000 Bytes aus.

- (a) Wie groß ist im Mittel der Overhead, der durch den verdeckten Kanal erzeugt wird?
- (b) Wie groß ist die Übertragungsrate des verdeckten Kanals, wenn der reguläre Kommunikationskanal eine Übertragungsrate von 100 Mbps hat?
- (c) Überlegen Sie, wie der verdeckte Kanal verhindert werden könnte, ohne die normale Netzwerkkommunikation zu stören?